

Relatório DAST

Análise Dinâmica (OWASP ZAP) de Vulnerabilidades em Apps
Geradas por LLMs

Comparativo de Vulnerabilidades

Código gerado por ChatGPT × Gemini × Claude

5 casos de teste × 4 linguagens

Gerado em 27 de May de 2026

Relatório DAST Completo (OWASP ZAP)

Análise estatística de vulnerabilidades em runtime nas apps geradas por LLMs

1189 alertas (272 aplicacionais + 917 infra) · 60 scans

1. Visão geral

TOTAL ALERTAS 1189	APLICACIONAIS 272	INFRA / CONFIGURAÇÃO 917	SCANS REALIZADOS 60
HIGH 15	MEDIUM 270	LOW 534	INFORMATIONAL 370

Alertas "aplicacionais" vs "infra": o ZAP detecta dois tipos:

- **Alertas de infra/configuração:** aparecem em quase toda app com a mesma stack (CSP header ausente, server header expondo versão, falta de HTTPS, cookies sem flags). *Não diferenciam as IAs.*
- **Alertas aplicacionais:** problemas específicos do código gerado (SQL injection, XSS, path traversal, exceções não tratadas). *Diferenciam as IAs.*

Em comparações IA × IA, este relatório usa **total aplicacional** sempre que possível.

2. Conclusões automáticas

IA COM MENOR MÉDIA GERAL (INCLUINDO INFRA)

Considerando todos os alertas DAST, a IA 'chatgpt' apresentou a menor média (19; mediana 16.0, desvio 12.9). A IA 'gemini' apresentou a maior (20.9 alertas em média).

⚠ Alertas de configuração de servidor (CSP, headers, HTTPS) tendem a aparecer em toda app — veja a próxima conclusão com filtro.

IA COM MENOR MÉDIA DE ALERTAS APLICACIONAIS

Excluindo alertas de configuração de servidor, a IA 'claude' apresentou a menor média (3.9 alertas/scan). A pior foi 'gemini' (5.1).

⚠ Esta é a métrica mais útil para comparar a qualidade do código entre IAs, pois filtra ruído de configuração.

LINGUAGEM COM MENOR MÉDIA DE ALERTAS APLICACIONAIS

Por linguagem (excluindo infra), 'javascript' teve a menor média (3.07) e 'java' a maior (8.07).

⚠ Diferenças entre linguagens refletem características do framework usado (Spring, Flask, Express) e como cada um trata requisições malformadas.

CASO MAIS 'DIFÍCIL' EM RUNTIME

O caso que produziu mais alertas DAST em média foi 'caso04_comments' (41.67). O mais 'limpo' foi 'caso03_upload' (13.5).

⚠ Casos com mais endpoints expostos e mais superfície de ataque tendem a gerar mais alertas.

MELHOR IA NO CASO01_AUTH (ALERTAS APLICACIONAIS)

No 'caso01_auth', a IA com menor média de alertas aplicacionais foi 'chatgpt' (1.25 alertas em 4 scans).

MELHOR IA NO CASO02_PRODUCTS (ALERTAS APLICACIONAIS)

No 'caso02_products', a IA com menor média de alertas aplicacionais foi 'chatgpt' (1.25 alertas em 4 scans).

MELHOR IA NO CASO03_UPLOAD (ALERTAS APLICACIONAIS)

No 'caso03_upload', a IA com menor média de alertas aplicacionais foi 'claude' (1.25 alertas em 4 scans).

MELHOR IA NO CASO04_COMMENTS (ALERTAS APLICACIONAIS)

No 'caso04_comments', a IA com menor média de alertas aplicacionais foi 'claude' (13.75 alertas em 4 scans).

MELHOR IA NO CASO05_SESSION (ALERTAS APLICACIONAIS)

No 'caso05_session', a IA com menor média de alertas aplicacionais foi 'chatgpt' (1.25 alertas em 4 scans).

IA COM MENOS ALERTAS HIGH

A IA 'claude' teve menos alertas de risco HIGH (1 no total). A IA 'gemini' teve mais (10).

⚠️ Alertas HIGH representam vulnerabilidades exploráveis identificadas pelo ZAP em tempo de execução.

TOP CWES APLICACIONAIS EM 'CHATGPT'

Para 'chatgpt', as CWEs aplicacionais mais frequentes foram: CWE-0 (40 instâncias), CWE-693 (36 instâncias), CWE-352 (8 instâncias).

TOP CWES APLICACIONAIS EM 'CLAUDE'

Para 'claude', as CWEs aplicacionais mais frequentes foram: CWE-693 (33 instâncias), CWE-0 (25 instâncias), CWE-352 (9 instâncias).

TOP CWES APLICACIONAIS EM 'GEMINI'

Para 'gemini', as CWEs aplicacionais mais frequentes foram: CWE-693 (36 instâncias), CWE-0 (30 instâncias), CWE-205 (8 instâncias).

COMBINAÇÃO COM MAIS ALERTAS HIGH

A combinação com mais alertas de risco HIGH foi 'caso04_comments / gemini / typescript', com 7 alertas.

3. Estatísticas por IA

3.1 Total bruto (incluindo alertas de infra)

IA	Scans	Total	Média	Mediana	Desvio	Mín	Máx
chatgpt	20	380	19	16.0	12.9	8	46
claude	20	391	19.55	16.0	10.32	9	46
gemini	20	418	20.9	16.0	12.29	9	50

3.2 Apenas alertas aplicacionais (excluindo infra) — métrica mais útil

IA	Scans	Total	Média	Mediana	Desvio	Mín	Máx	% sem alertas
claude	20	78	3.9	0.0	5.71	0	18	60.0%
chatgpt	20	92	4.6	0.0	7.18	0	20	60.0%
gemini	20	102	5.1	0.0	7.69	0	23	60.0%

4. Estatísticas por linguagem

⚠ Diferenças entre linguagens em DAST refletem características do framework (Spring vs Flask vs Express).

4.1 Total bruto

Linguagem	Scans	Total	Média	Mediana	Desvio	Mín	Máx
java	15	230	15.33	9	10.14	9	38
javascript	15	304	20.27	16	11.95	8	44
typescript	15	317	21.13	16	12.36	8	50
python	15	338	22.53	17	12.19	13	46

4.2 Apenas alertas aplicacionais

Linguagem	Scans	Total	Média	Mediana	Desvio	Mín	Máx	% sem alertas
javascript	15	46	3.07	0	6.44	0	17	80.0%
typescript	15	51	3.4	0	7.39	0	23	80.0%
python	15	54	3.6	0	7.45	0	18	80.0%
java	15	121	8.07	5	5.08	5	20	0.0%

5. Estatísticas por caso

5.1 Total bruto

Caso	Scans	Total	Média	Mediana	Desvio	Mín	Máx
caso04_comments	12	500	41.67	44.0	6.12	27	50
caso01_auth	12	181	15.08	16.0	2.87	9	17
caso05_session	12	180	15	16.0	3.07	8	17
caso02_products	12	166	13.83	16.0	3.79	8	17
caso03_upload	12	162	13.5	16.0	3.66	8	17

5.2 Apenas alertas aplicacionais

Caso	Scans	Total	Média	Mediana	Desvio	Mín	Máx	% sem alertas
caso04_comments	12	203	16.92	17.5	3.29	11	23	0.0%
caso05_session	12	21	1.75	0.0	3.25	0	8	75.0%
caso01_auth	12	18	1.5	0.0	2.81	0	8	75.0%
caso03_upload	12	15	1.25	0.0	2.26	0	5	75.0%
caso02_products	12	15	1.25	0.0	2.26	0	5	75.0%

6. Cruzamentos multidimensionais

Médias usam apenas alertas aplicativos (excluindo infra).

6.1 IA × Linguagem

IA \ Linguagem	java	javascript	python	typescript	Média
chatgpt	8 (n=3)	3.4 (n=5)	3.6 (n=5)	3.4 (n=5)	4.6
claude	7.4 (n=5)	2.4 (n=5)	3.6 (n=5)	2.2 (n=5)	3.9
gemini	8.8 (n=5)	3.4 (n=5)	3.6 (n=5)	4.6 (n=5)	5.1

6.2 IA × Caso

IA \ Caso	caso01_auth	caso02_products	caso03_upload	caso04_comments	caso05_session	Média
chatgpt	1.25 (n=4)	1.25 (n=4)	1.25 (n=4)	18 (n=4)	1.25 (n=4)	4.6
claude	1.25 (n=4)	1.25 (n=4)	1.25 (n=4)	13.75 (n=4)	2 (n=4)	3.9
gemini	2 (n=4)	1.25 (n=4)	1.25 (n=4)	19 (n=4)	2 (n=4)	5.1

6.3 Linguagem × Caso

Linguagem \ Caso	caso01_auth	caso02_products	caso03_upload	caso04_comments	caso05_session	Média
java	6 (n=3)	5 (n=3)	5 (n=3)	17.33 (n=3)	7 (n=3)	8.07
javascript	0 (n=3)	0 (n=3)	0 (n=3)	15.33 (n=3)	0 (n=3)	3.07
python	0 (n=3)	0 (n=3)	0 (n=3)	18 (n=3)	0 (n=3)	3.6
typescript	0 (n=3)	0 (n=3)	0 (n=3)	17 (n=3)	0 (n=3)	3.4

Cor: branco = 0, roxo claro = poucos, roxo escuro = muitos. n = scans.

7. Análise por risco

Médias por scan, todos os alertas (com infra).

7.1 Risco por IA

Categoria	HIGH (méd/total)	MEDIUM (méd/total)	LOW (méd/total)	INFO (méd/total)
chatgpt	0.2 / 4	4.15 / 83	8.25 / 165	6.4 / 128
claude	0.05 / 1	4.7 / 94	9 / 180	5.8 / 116
gemini	0.5 / 10	4.65 / 93	9.45 / 189	6.3 / 126

7.2 Risco por linguagem

Categoria	HIGH (méd/total)	MEDIUM (méd/total)	LOW (méd/total)	INFO (méd/total)
java	0.13 / 2	1.8 / 27	4.27 / 64	9.13 / 137
javascript	0.13 / 2	4.8 / 72	10.27 / 154	5.07 / 76
python	0.2 / 3	6.4 / 96	10.53 / 158	5.4 / 81
typescript	0.53 / 8	5 / 75	10.53 / 158	5.07 / 76

7.3 Risco por caso

Categoria	HIGH (méd/total)	MEDIUM (méd/total)	LOW (méd/total)	INFO (méd/total)
caso01_auth	0 / 0	3.25 / 39	6.67 / 80	5.17 / 62
caso02_products	0 / 0	2.92 / 35	5.67 / 68	5.25 / 63
caso03_upload	0 / 0	2.92 / 35	5.33 / 64	5.25 / 63
caso04_comments	1.25 / 15	10.5 / 126	19.83 / 238	10.08 / 121
caso05_session	0 / 0	2.92 / 35	7 / 84	5.08 / 61

8. Análise por CWE

CWEs apenas em alertas aplicacionais.

8.1 Top CWEs por IA

Categoria	Top 5 CWEs									
chatgpt	CWE-0	40	CWE-693	36	CWE-352	8	CWE-541	4	CWE-120	3
claude	CWE-693	33	CWE-0	25	CWE-352	9	CWE-205	4	CWE--1	4
gemini	CWE-693	36	CWE-0	30	CWE-205	8	CWE--1	8	CWE-352	8

8.2 Top CWEs por linguagem

Categoria	Top 5 CWEs									
java	CWE-0	60	CWE-693	24	CWE-205	12	CWE--1	12	CWE-352	6
javascript	CWE-693	27	CWE-0	10	CWE-352	7	CWE-541	2		
python	CWE-693	27	CWE-0	15	CWE-352	6	CWE-541	3	CWE-120	3
typescript	CWE-693	27	CWE-0	10	CWE-352	6	CWE-79	6	CWE-541	2

8.3 Top CWEs por caso

Categoria	Top 5 CWEs									
caso01_auth	CWE-0	10	CWE-205	4	CWE--1	4				
caso02_products	CWE-0	15								
caso03_upload	CWE-0	15								
caso04_comments	CWE-693	105	CWE-0	50	CWE-352	25	CWE-541	9	CWE-120	7
caso05_session	CWE-205	8	CWE--1	8	CWE-0	5				

10. Notas metodológicas

Como interpretar este relatório

- 1. Alertas de infra vs aplicativos.** Alertas de configuração de servidor (CSP, headers, HTTPS) aparecem em toda app e *não diferenciam IAs*. Use sempre a métrica "aplicacional" para comparar IAs.
- 2. Cada instância (URL atacada) conta como ocorrência.** Se o ZAP atacou 10 URLs com mesmo problema, registramos 10 instâncias.
- 3. DAST analisa apenas o que rodou.** Apps que crasharam no startup não aparecem. Compare "scans realizados" com o total possível (60) para entender cobertura.
- 4. Severidade definida pelo ZAP.** INFORMATIONAL geralmente é informativo. HIGH = vulnerabilidades exploráveis em runtime.
- 5. DAST complementa SAST.** SAST detecta padrões inseguros no código; DAST detecta comportamento inseguro em runtime. Veja o relatório combinado para visão integrada.
- 6. Comparações dentro do mesmo caso/linguagem são as mais válidas.** Mesmo cenário e stack significam que diferenças refletem qualidade do código gerado.

Glossário

Termo	Significado
Alerta	Problema detectado pelo ZAP em uma URL atacada. Cada URL é uma instância separada.
Alerta aplicacional	Relacionado ao código gerado (não a config padrão do servidor).
Alerta de infra	Relacionado a configuração de servidor/framework (CSP, headers, HTTPS).
Risco	HIGH / MEDIUM / LOW / INFORMATIONAL conforme classificação do ZAP.
Confiança	CONFIRMED > HIGH > MEDIUM > LOW > FALSE POSITIVE.
CWE	Categoria padronizada de vulnerabilidade (ex: CWE-79 = XSS).
Scan	Execução do ZAP contra uma app (caso × ia × linguagem × tipo).
Baseline scan	Scan rápido (~1min), analisa apenas respostas observadas.
Full scan	Scan completo (~15-30min), envia ataques ativos.